

Report 29/04/2026

Alunno : Pancrazio Giuzio

Traccia:

Quanti e quali sono i livelli su cui è basato il sistema di valutazione di ThreatConnect?

Analizza la lista di best practice ThreatConnect:

<https://knowledge.threatconnect.com/docs/best-practices-indicator-threat-and-confidence-ratings>

Compila una lista spiegando, per ogni livello, le caratteristiche.

Facoltativo: Esercizio Esercizio Creare un elenco di minacce comuni che possono colpire un'azienda, ad esempio phishing, malware, attacchi DDoS, furto di dati. •

Inizia raccogliendo informazioni sulle minacce alla sicurezza informatica, utilizzando fonti aperte, i siti web di sicurezza informatica e i forum di discussione. • Analizza ciascuna minaccia in dettaglio, cercando di comprendere il modo in cui può essere utilizzata per compromettere la sicurezza informatica e i danni che può causare. • Utilizza queste informazioni per creare un elenco delle minacce più comuni, tra cui malware, attacchi di phishing e attacchi DDoS aggiungendo tutte le informazioni raccolte dall'analisi.

Il sistema di valutazione di Threat Connect è principalmente un sistema basato su due fonti , ovvero il threat rating , dove si misura l'impatto potenziale della minaccia , basato su asset dell'azienda o sistemi ad essi connessa . l'altra fonte è il confidence rating, ovvero la veridicità possibile e riscontrabile confrontata all'azione di minaccia , questi due sistemi di valutazione sono hanno una base numerica da uno a 5 e una percentuale dallo 0 al 100 , vengono combinate insieme per capire realmente i quadri generali che possono risultare come vere minacce impattanti o meno .

Per il threat rating (livello di pericolo di solito ci confrontiamo con una tabella del genere.

Livello 0 – Sconosciuto

L'indicatore è nel sistema ma non ci sono dati sufficienti per valutarlo. È un punto interrogativo.

Livello 1 – Innocuo

Soggetti certamente sicuri e verificati. Serve a inserire nelle "white list" servizi affidabili come Google o Microsoft per evitare errori.

Livello 2 – Basso

Rischio minimo. Si tratta solitamente di adware, spam o programmi fastidiosi che non causano danni strutturali ma vanno comunque gestiti.

Livello 3 – Moderato

Minacce reali ma diffuse su larga scala, come il malware comune o le campagne di phishing che non hanno un bersaglio specifico.

Livello 4 – Alto

Pericolo serio e mirato. Indica attacchi sofisticati, spyware o tentativi di intrusione da parte di gruppi hacker esperti.

Livello 5 – Critico

Il massimo grado di allerta. Include ransomware distruttivi, vulnerabilità non ancora note (Zero-day) o attacchi diretti da parte di attori statali.

sempre in 5 livelli il confidence rating .

0% – Nessuna

Nessuna prova a supporto. L'informazione è considerata un'ipotesi o è troppo vecchia per essere ritenuta valida.

25% – Bassa

L'affidabilità è scarsa. La fonte potrebbe non essere verificata o l'evidenza tecnica è molto debole.

50% – Media

Esistono indizi concreti ma non c'è ancora una conferma definitiva. È una segnalazione che merita attenzione ma richiede ulteriori verifiche.

75% – Alta

L'informazione è solida. Proviene da fonti affidabili e i dati sono stati incrociati con successo con altre analisi.

100% – Molto Alta

Certezza assoluta. La minaccia è stata osservata direttamente sui sistemi o confermata da analisi tecniche inconfutabili.

Analizzando queste due tabelle con le informazioni in nostro possesso possiamo definire quindi il livello di minaccia .

visitando la pagina del clusit , si può avere una panoramica di quelle che sono attualmente le minacce più comuni e significative in crescita dal 2024/2025

Ecco un elenco delle minacce principali analizzate secondo la loro natura, il vettore d'attacco e l'impatto potenziale:

1. Malware & Ransomware

È il software malevolo progettato per infiltrarsi o danneggiare un sistema. Oggi la variante regina è il Ransomware, che cifra i dati aziendali e chiede un riscatto.

Come colpisce: Allegati email, vulnerabilità di software non aggiornati o chiavette USB infette.

Danni: Blocco totale dell'operatività, perdita definitiva di dati e costi di ripristino altissimi.

Valutazione tipica:

Threat Livello 5 (Critico) | Confidence 75-100% (se rilevato da antivirus/SOC).

2. Phishing & Ingegneria Sociale

Tecniche di manipolazione per convincere i dipendenti a rivelare password o scaricare malware. Si è evoluto nel *BEC (Business Email Compromise)*, dove l'attaccante finge di essere un dirigente o un fornitore per autorizzare bonifici falsi.

Come colpisce: Email, SMS (Smishing) o chiamate (Vishing) estremamente realistiche.

Danni: Furto di credenziali d'accesso ai sistemi core e perdite finanziarie dirette.

Valutazione tipica: Threat Livello 3-4 (Moderato/Alto) | Confidence 50-75% (spesso richiede verifica umana).

3. Attacchi DDoS (L'interruzione del servizio)

Il *Distributed Denial of Service* punta a saturare le risorse di un server o di una rete, rendendo i servizi aziendali (come il sito web o l'e-commerce) irraggiungibili. Come colpisce: Una rete di computer infetti (Botnet) inonda il target di traffico spazzatura.

Danni: Interruzione delle vendite, danni d'immagine e potenziale "schermo" per altri attacchi più silenziosi

Valutazione tipica: Threat Livello 3 (Moderato) | Confidence 100% (l'effetto è immediato e visibile).

4. Violazione delle API e della Supply Chain (Il nuovo perimetro)

Come evidenziato dal Clusit 2026, l'interconnessione tra software e partner è un punto critico. Colpire un fornitore IT significa entrare in tutte le aziende che usano i suoi servizi. Come colpisce: Sfruttando falle nei codici delle API o compromettendo gli aggiornamenti software di terze parti.

Danni: Accesso massivo a database clienti e proprietà intellettuale senza passare per il perimetro principale.

Valutazione tipica: Threat Livello 5 (Critico) | Confidence 25-50% (molto difficile da individuare inizialmente).

5. Data Breach / Furto di Dati (L'obiettivo finale)

L'esfiltrazione di informazioni sensibili, dai dati personali dei dipendenti ai segreti industriali.

Come colpisce: Spesso è il risultato finale di uno degli attacchi sopra citati.

Danni: Sanzioni pesanti (GDPR), cause legali e perdita del vantaggio competitivo.

Valutazione tipica: Threat Livello 4 (Alto) | Confidence 100% (una volta che i dati appaiono nel Dark Web).

In conclusione il sistema di valutazione di ThreatConnect si rivela uno strumento fondamentale per chi deve gestire la sicurezza aziendale ogni giorno. Il suo pregio principale è la capacità di filtrare il rumore di fondo permettendo di passare da una gestione caotica delle emergenze a un approccio ordinato e basato sulle priorità. Attraverso il bilanciamento tra la gravità del pericolo e l'affidabilità della notizia il team di sicurezza può decidere con precisione quando è il momento di intervenire con la massima forza e quando invece basta un semplice monitoraggio. In un panorama come quello attuale dove le minacce evolvono rapidamente questo metodo offre una struttura solida per non farsi trovare impreparati e per proteggere gli asset più preziosi dell'azienda in modo intelligente.

Traccia: Per ogni scenario proposto identifica: • OWASP Top 10 (se presente); • MITRE ATT&CK Enterprise (tecnica principale); • Mitigazione suggerita da MITRE ATT&CK.

Scenari:

1. Esercizio Traccia Un'azienda ha ricevuto segnalazioni da utenti che hanno subito attacchi XSS. Gli utenti hanno inserito dati in un form online che eseguiva script dannosi nel loro browser. Questo ha permesso agli attaccanti di rubare i cookie di sessione e impersonare altri utenti.
2. Un attaccante è riuscito a ottenere accesso non autorizzato ai dati aziendali sfruttando una vulnerabilità SQL Injection nell'interfaccia di login di un'applicazione. L'attaccante ha manipolato l'input per eseguire comandi SQL non autorizzati, estraendo dati sensibili dal database.
3. Un attaccante è riuscito a eseguire codice arbitrario sul server sfruttando una vulnerabilità di deserializzazione non sicura del client in una funzione che accetta oggetti serializzati dall'utente. Manipolando l'oggetto inviato, l'attaccante ha ottenuto l'esecuzione remota di codice sul server.

Prima di analizzare i casi specifici è utile definire i due strumenti che useremo per la classificazione perché offrono due punti di vista diversi ma complementari sulla sicurezza. Owasp è una fondazione senza scopo di lucro che si concentra sulla sicurezza delle applicazioni web. Il suo documento più famoso è la top ten che elenca i dieci rischi più critici per le applicazioni online aggiornandoli periodicamente in base ai dati raccolti a livello mondiale. In pratica questo framework ci dice quali sono i difetti di programmazione o le mancanze di configurazione che gli sviluppatori devono correggere per rendere sicuro un sito o un servizio web.

Mitre att&ck è invece una base di conoscenza globale che cataloga le tattiche e le tecniche utilizzate dagli hacker durante gli attacchi reali. Mentre le owasp guardano ai buchi nel codice il mitre guarda al comportamento dell'attaccante. È strutturato come una matrice che descrive tutto il percorso di un intruso dal momento in cui cerca di entrare nel sistema fino a quando riesce a rubare i dati o causare danni fornendo per ogni azione le contromisure da adottare.

Scenario uno: attacchi xss tramite form online per furto di cookie

In questo caso il riferimento owasp è la categoria injection A03:2021 che include proprio i cross site scripting poiché il sistema accetta codice malevolo che viene poi eseguito nel browser della vittima owasp.org Nella matrice mitre att&ck la tecnica principale è identificata come exploit public facing application T1190 dato che l'attaccante sfrutta una vulnerabilità su un servizio web esposto mitre.org La mitigazione suggerita M1050 consiste nella validazione e nella sanificazione sistematica di ogni input inserito dagli utenti per impedire l'esecuzione di script oltre all'utilizzo di attributi di sicurezza per i cookie che ne impediscono la lettura tramite script mitre.org

Scenario due: accesso non autorizzato tramite sql injection

Questo scenario rientra sempre nella categoria injection A03:2021 delle owasp essendo l'esempio più classico di manipolazione delle query verso un database owasp.org Per il mitre att&ck la tecnica rimane exploit public facing application T1190 ma l'obiettivo si sposta verso l'accesso ai dati o l'escalation dei privilegi mitre.org La mitigazione principale proposta dal mitre M1050 prevede l'uso di query parametrizzate e procedure memorizzate che separano il codice dai dati inseriti dall'utente rendendo impossibile l'esecuzione di comandi non previsti dallo sviluppatore mitre.org

Scenario tre: esecuzione remota di codice tramite deserializzazione non sicura

Nelle owasp questa vulnerabilità è classificata sotto la voce software and data integrity failures A08:2021 che riguarda proprio i difetti nel modo in cui i dati vengono gestiti e trasformati tra client e server owasp.org Secondo il framework mitre att&ck l'attaccante sta utilizzando una tecnica di application exploit T1190 per ottenere quella che viene definita esecuzione di codice remoto mitre.org La mitigazione suggerita M1042 consiste nel non accettare mai oggetti serializzati da fonti non fidate o nel limitare drasticamente le classi che possono essere elaborate dal sistema applicando controlli rigorosi prima della ricostruzione dell'oggetto sul server mitre.org

In conclusione, l'integrazione di questi framework permette di passare da una gestione approssimativa a una difesa professionale e strutturata. L'utilizzo della classificazione OWASP Top 10, come la categoria A03:2021 dedicata alle Injection owasp.org o la A08:2021 focalizzata sull'integrità dei dati owasp.org consente di identificare e correggere i difetti strutturali delle applicazioni prima che vengano sfruttati.

Parallelamente, l'adozione del framework MITRE ATT&CK permette di mappare il comportamento reale degli avversari attraverso tecniche specifiche come la T1190 relativa allo sfruttamento di applicazioni esposte mitre.org fornendo una visione chiara di come una vulnerabilità si trasformi in un attacco concreto. Questo approccio combinato guida l'azienda nella scelta delle giuste mitigazioni, come la M1050 per la protezione dagli exploit mitre.org o la M1042 per la gestione degli aggiornamenti e delle configurazioni sicure mitre.org garantendo che ogni investimento in sicurezza sia mirato e supportato da dati condivisi a livello globale.

Tutto il materiale e i codici utilizzati fanno riferimento al Framework MITRE ATT&CK e al OWASP